
Compliance Mapping

NIST SSDF, OWASP ASVS, CIS Kubernetes Benchmark, SLSA, SOC 2 style, ISO 27001 style, PCI/HIPAA alignment only

Project: Enterprise DevSecOps Security Lab

Author: Jagriti Banerjee

Artifact: compliance_mapping.md

Assessment Context

Maps implemented DevSecOps lab controls to enterprise security and compliance frameworks using evidence-based traceability.

Confidentiality: Portfolio lab documentation. Compliance mappings are control-alignment artifacts only and are not formal certifications, attestations, or legal compliance opinions.

1. Executive Summary

This compliance mapping document connects the Enterprise DevSecOps Security Lab controls to secure software development, application security, Kubernetes hardening, supply-chain integrity, monitoring, and audit-readiness frameworks. The objective is to demonstrate how the project evidence supports enterprise-style governance expectations without claiming formal certification.

The mapping is intentionally evidence-driven. Each control maps to implemented project artifacts such as GitHub Actions security gates, Bandit and pip-audit reports, Trivy scans, Kubernetes manifests, ArgoCD GitOps evidence, Cosign signature verification, Syft SBOM files, Falco detections, Prometheus rules, Grafana dashboards, and documented exceptions.

2. Mapping Scope and Assumptions

- Scope covers a private lab environment, vulnerable Flask application, Docker image, GitHub Actions pipeline, Kind Kubernetes cluster, GitOps deployment, supply-chain artifacts, and runtime detection stack.
- NIST SSDF, OWASP ASVS, CIS Kubernetes Benchmark, and SLSA are treated as primary technical reference frameworks.
- SOC 2 and ISO 27001 are mapped in a style-control format because this is a portfolio lab, not a formal audit engagement.
- PCI DSS and HIPAA mappings are alignment-only because the lab does not process payment account data or electronic protected health information.
- Evidence artifacts are intended to support recruiter review, security engineering discussion, and audit-readiness demonstration.

3. Compliance Control Domains

Domain	Implemented Capability	Primary Evidence	Business / Audit Value
Secure SDLC	Security requirements and threat-aware design are documented before implementation.	methodology.pdf; ci-cd-threat-model.pdf; OWASP mapping PDF; AppSec test cases PDF	Supports traceability, repeatable validation, and control ownership.
SAST	Static application security testing is executed for Python code.	bandit-summary.pdf; security-gates.yml; Bandit SARIF artifacts	Supports traceability, repeatable validation, and control ownership.
SCA	Dependency vulnerabilities are detected and tracked.	pip_audit_summary.pdf; dependency_vulnerability_finding.pdf	Supports traceability, repeatable validation, and control ownership.
Secret Security	Repository and filesystem scans detect exposed credentials/secrets.	security-gates.yml; Trivy FS report	Supports traceability, repeatable validation, and control ownership.
Container Hardening	Container image is hardened before deployment.	Dockerfile; Trivy image scan; secure code remediation examples	Supports traceability, repeatable validation, and control ownership.
Image Signing	Container image integrity is verified using Cosign.	Cosign/Syft/SBOM Enterprise Evidence PDF; cosign verify output	Supports traceability, repeatable validation, and control ownership.
SBOM	SBOM is generated and retained in SPDX/CycloneDX formats.	SBOM summary PDF; sbom-spxd.json; sbom-cyclonedx.json	Supports traceability, repeatable validation, and control ownership.
Provenance	Build provenance is generated and attested.	provenance_summary.pdf; slsa-provenance.json; cosign attestation verification	Supports traceability, repeatable validation, and control ownership.

Domain	Implemented Capability	Primary Evidence	Business / Audit Value
GitOps	Cluster state is managed from Git and drift is corrected.	ArgoCD resource tree; self-heal screenshots; devsecops_pipeline_deep_dive.pdf	Supports traceability, repeatable validation, and control ownership.
Kubernetes RBAC	Workload identity follows least privilege.	rbac_review.pdf; kubectl auth can-i outputs	Supports traceability, repeatable validation, and control ownership.
Network Policy	Default-deny and explicit allow traffic rules are applied.	network_policy_validation.pdf; allow/block curl pod evidence	Supports traceability, repeatable validation, and control ownership.
Pod Security	Unsafe workload configurations are blocked.	pod_security_validation.pdf; privileged pod blocked evidence	Supports traceability, repeatable validation, and control ownership.
Admission Control	Policy-as-code enforces metadata and deployment hygiene.	Gatekeeper templates and blocked/allowed deployment screenshots	Supports traceability, repeatable validation, and control ownership.
Runtime Detection	Runtime threats are detected and routed into observability stack.	detection report; Falco rule analysis; Falco alerts	Supports traceability, repeatable validation, and control ownership.
Observability	Security telemetry is monitored and alert rules are defined.	falco_security_dashboard.json PDF; prometheus_rules YAML PDF; Grafana screenshots	Supports traceability, repeatable validation, and control ownership.
Risk & Exceptions	Residual risk is documented and exceptions have owners and expiry.	risk_register.csv; vulnerability_exceptions.pdf; VEX notes PDF	Supports traceability, repeatable validation, and control ownership.

4. Detailed Framework Mapping Matrix

The following matrix maps implemented controls to the requested compliance and security frameworks. Control IDs are reused across the control validation matrix, risk register, and audit summary to preserve traceability.

ID	Domain	Implemented Control	NIST SSDF	OWASP ASVS	CIS K8s	SLSA	SOC 2 / ISO 27001 / PCI-HIPAA Alignment
CTRL-01	Secure SDLC	Security requirements and threat-aware design are documented before implementation. Methodology, CI/CD threat model, AppSec test cases, OWASP ASVS mapping, and finding-specific reports.	PO.1, PO.2, PW.1	V1, V2, V5, V14	N/A	Build platform and source integrity planning	SOC 2 CC2/CC3/CC7 style; ISO A.5/A.8 style PCI secure development alignment; HIPAA technical safeguard alignment
CTRL-02	SAST	Static application security testing is executed for Python code. Bandit workflow scans src/app and publishes artifacts; gate thresholds can fail builds.	PW.7, RV.1	V5 input validation, V14 config	N/A	Quality gate prior to artifact build	SOC 2 CC7; ISO vulnerability mgmt style PCI 6.x alignment; HIPAA technical safeguards alignment
CTRL-03	SCA	Dependency vulnerabilities are detected and tracked. pip-audit scans requirements.txt and flags vulnerable packages.	PW.4, RV.1, RV.2	V14.2 dependency security	N/A	Dependency traceability and review	SOC 2 CC7; ISO A.8 vulnerability mgmt style PCI 6.x alignment; HIPAA risk management alignment
CTRL-04	Secret Security	Repository and filesystem scans detect exposed credentials/secrets. Trivy filesystem scan includes secret scanning; security gate fails on critical secret findings.	PS.3, PW.4, RV.1	V6 secrets handling; V14 config	N/A	Protect build/release secrets	SOC 2 CC6/CC7; ISO access control style PCI access restriction alignment; HIPAA access control alignment
CTRL-05	Container Hardening	Container image is hardened before deployment. Multi-stage Dockerfile, non-root user, read-only runtime expectations, healthcheck, and Trivy image scan.	PW.6, PW.8, RV.1	V14 configuration	CIS Docker/Kubernetes workload hardening alignment	Build artifact quality gate	SOC 2 CC7; ISO secure configuration style PCI system hardening alignment; HIPAA technical safeguards alignment
CTRL-06	Image Signing	Container image integrity is verified using Cosign. Cosign key-pair signing and signature verification performed for GHCR image.	PS.2, PW.6, RV.1	V14.2 build/dependency verification alignment	N/A	Artifact integrity and tamper resistance	SOC 2 CC6/CC7; ISO change protection style PCI software integrity alignment; HIPAA integrity alignment
CTRL-07	SBOM	SBOM is generated and retained in SPDX/CycloneDX formats. Syft generates SBOM package inventory; CycloneDX used for supply-chain transparency.	PS.3, PW.4, RV.1	V14 dependency inventory alignment	N/A	Dependency transparency	SOC 2 CC2/CC7; ISO asset inventory style PCI software inventory alignment; HIPAA asset/risk alignment
CTRL-08	Provenance	Build provenance is generated and attested. SLSA-style provenance describes repo, commit, builder, image digest, and build process.	PS.2, PS.3, PW.4	V14 build integrity alignment	N/A	Provenance and build integrity controls	SOC 2 CC7; ISO change management style PCI change control alignment; HIPAA integrity alignment
CTRL-09	GitOps	Cluster state is managed from Git and drift is corrected. ArgoCD automated sync, prune, and self-heal are configured.	PW.6, RV.3	V14 configuration management alignment	Change control and Kubernetes configuration alignment	Source-controlled deployment flow	SOC 2 CC7; ISO change control style PCI change management alignment; HIPAA integrity alignment
CTRL-10	Kubernetes RBAC	Workload identity follows least privilege. Dedicated ServiceAccount, minimal Role/RoleBinding, and no cluster-admin privileges for app workloads.	PO.5, PW.6	V4 access control alignment	RBAC and access control benchmark alignment	Protect deployment environment permissions	SOC 2 CC6; ISO access control style PCI least privilege alignment; HIPAA access control alignment

ID	Domain	Implemented Control	NIST SSDF	OWASP ASVS	CIS K8s	SLSA	SOC 2 / ISO 27001 / PCI-HIPAA Alignment
CTRL-1 1	Network Policy	Default-deny and explicit allow traffic rules are applied. Calico-backed NetworkPolicies restrict ingress/egress to trusted pods/namespaces and DNS.	PW.6, RV.1	V14 architecture/ config alignment	Network segmentation benchmark alignment	Protect deployment environment	SOC 2 CC6/CC7; ISO network security style PCI segmentation alignment; HIPAA transmission security alignment
CTRL-1 2	Pod Security	Unsafe workload configurations are blocked. Restricted Pod Security labels block privileged pods and hostPath patterns; securityContext hardening applied.	PW.6, RV.1	V14 configuration alignment	Pod security and workload hardening alignment	Protect runtime environment	SOC 2 CC7; ISO secure configuration style PCI hardening alignment; HIPAA technical safeguards alignment
CTRL-1 3	Admission Control	Policy-as-code enforces metadata and deployment hygiene. OPA Gatekeeper blocks non-compliant Deployments missing supply-chain labels.	PW.8, RV.1	V14 configuration and deployment alignment	Admission control alignment	Enforce release policy before deployment	SOC 2 CC7; ISO change policy style PCI change/release alignment; HIPAA policy alignment
CTRL-1 4	Runtime Detection	Runtime threats are detected and routed into observability stack. Falco detects sensitive file access, privileged pod behavior, and suspicious shell/container activity.	RV.1, RV.3	V14 operational security alignment	Runtime monitoring alignment	Detect deployment/runtime tampering signals	SOC 2 CC7; ISO logging and monitoring style PCI logging/monitoring alignment; HIPAA audit controls alignment
CTRL-1 5	Observability	Security telemetry is monitored and alert rules are defined. Falcosidekick exposes metrics; Prometheus scrapes; Grafana dashboard visualizes runtime detections.	RV.1, RV.3	V14 logging and monitoring alignment	Monitoring and audit logging alignment	Integrity signal monitoring	SOC 2 CC7; ISO monitoring style PCI audit logging alignment; HIPAA audit controls alignment
CTRL-1 6	Risk & Exceptions	Residual risk is documented and exceptions have owners and expiry. Risk register, vulnerability exceptions, and VEX notes document accepted risk and review criteria.	RV.2, RV.3	Risk-driven validation alignment	Exception tracking for benchmark deviations	Known gaps in supply-chain posture documented	SOC 2 CC3/CC4; ISO risk treatment style PCI/HIPAA risk management alignment only

5. Framework-Specific Narrative Mapping

NIST SSDF Alignment

The lab demonstrates SSDF-style practices by defining security requirements, scanning source code, reviewing third-party dependencies, producing evidence during CI/CD, documenting vulnerabilities, and validating remediation. The strongest mapped areas are secure development practices, vulnerability response, and build/release evidence.

OWASP ASVS Alignment

The Flask app findings are mapped to ASVS technical verification themes including input validation, access control concepts, dependency management, configuration management, and operational security. ASVS is used as a testable application security requirements baseline rather than a high-level awareness list.

CIS Kubernetes Benchmark Alignment

The Kubernetes evidence aligns to workload hardening, RBAC review, pod security, network segmentation, auditability, and secure configuration expectations. kube-bench results and Kubernetes hardening checklists serve as benchmark evidence where applicable.

SLSA Alignment

SLSA alignment is demonstrated through source-controlled workflows, build integrity evidence, image signing, SBOM generation, provenance records, and tamper-resistance discussion. The lab uses SLSA-style provenance and explicitly notes that local lab provenance is not a full trusted-builder attestation.

SOC 2 Style Control Alignment

The project maps to security, availability, confidentiality, and processing integrity themes through access control, change control, monitoring, incident response, vulnerability management, and audit evidence.

ISO 27001 Style Control Alignment

The project maps to information security management themes including risk assessment, asset inventory, access control, secure development, supplier/dependency risk, logging, monitoring, vulnerability management, and continual improvement.

PCI/HIPAA Alignment Only

PCI and HIPAA are included only as directional alignment. The lab does not process cardholder data or ePHI. The relevant alignment areas are secure development, vulnerability management, access control, audit logging, change management, segmentation, and risk management.

References and Alignment Sources

The following references were used as control-alignment sources. The PCI and HIPAA mappings in this portfolio lab are alignment-only and do not represent formal compliance validation, attestation, or certification.

Source	Reference	Use in this document
NIST SSDF	NIST SP 800-218 SSDF v1.1	Secure software development practices used as SDLC control baseline.
OWASP ASVS	OWASP ASVS 5.0.0	Technical verification requirements for application security controls.
CIS Kubernetes Benchmark	Center for Internet Security Kubernetes Benchmark	Consensus-based secure configuration guidance for Kubernetes.
SLSA	Supply-chain Levels for Software Artifacts	Framework/checklist for preventing tampering and improving artifact integrity.
SOC 2 style	AICPA Trust Services Criteria	Control themes aligned to security, availability, confidentiality, and processing integrity.
ISO 27001 style	ISO/IEC 27001:2022	Information security management system control alignment.
PCI alignment only	PCI DSS security requirements	Alignment to protection of cardholder-data environments; no PCI validation claimed.
HIPAA alignment only	HIPAA Security Rule	Alignment to administrative, physical, and technical safeguard themes; no HIPAA compliance opinion claimed.